

Privacy Impact Assessment — School Sport Portal

Version: 1.0 — May 2026 **Prepared for:** Australian Government, Catholic, and Independent Schools considering adopting School Sport Portal (SSP) and associated products. **Prepared by:** Luck Dragon Pty Ltd (operator of schoolsportportal.com.au, carnivaltiming.com, sportcarnival.com.au).

This PIA is provided so school business managers can attach it to a council/board submission. School-specific addenda are provided per jurisdiction at the end.

1. The proposal

The school proposes to use **School Sport Portal** (SSP) and associated tools for the administration of inter-school and intra-school sport: roster management, event scheduling, race-day timing, and publication of results.

Products covered

Product	Purpose
School Sport Portal (schoolsportportal.com.au)	Roster + calendar + reporting
Carnival Timing (carnivaltiming.com)	Race-day timing app — start, lane, finish, results
SportCarnival (sportcarnival.com.au)	Public results page (optional, opt-in per carnival)

Pricing model

\$1 per enrolled student per year. Schools can opt out of public results publication and remain on the platform.

2. Information flows

Data collected

Students: Given name, surname, year level, date of birth (year only), house, gender, sport results (times, places). No address, parent name, medical condition, ATSI status, or photograph is collected by SSP.

School staff (admin / coach): Name, email, role, password hash.

Parents (optional): If school enables parent-view feature — parent name + email only, linked to one or more students.

Public viewers: No account required; no personal data collected. Published results show first name + surname-initial by default (e.g., “Henry F”); full surname is opt-in per school.

How collected

- Bulk CSV upload by school admin (from school SIS — Compass, Sentral, Edumate, etc.).
- Race-day entry by SSP-trained school staff (bib + time only).
- Optional parent self-registration if the school enables it.

How used

- To administer school sport events.
- To produce results pages, ladders, and historical records for the school.
- To produce de-identified product analytics (counts only — never identifiable).

How stored

- Cloudflare D1 (database) — Sydney edge region.
- Cloudflare KV — Sydney edge region.
- Cloudflare R2 (object storage, logos / file attachments only).
- All encrypted at rest by the platform.

How transmitted

- HTTPS only, TLS 1.2 minimum, HSTS enforced.
- API tokens HMAC-signed and rotated.

Who sees it

- The contracting school's authorised admins and coaches.
- Luck Dragon Pty Ltd staff (sole director Patrick Gallivan only) for support and platform operations.
- Cloudflare Inc. (hosting subprocessor — see § 6).
- Stripe Inc. (payments — schools only; no student data).
- Resend Inc. (transactional email — adult addresses only).
- The public, **only** for results published with school consent.

How long retained

- Active student records: while enrolled + current year.
- Historical results: 7 years (matches school records-retention norms).
- Logs: 90 days.
- Backups: 30 days rolling.
- On request, all records can be exported and deleted within 14 days of school's written request.

3. Privacy risks identified

#	Risk	Likelihood	Impact	Treatment
1	Unauthorised access to student records via stolen admin credential	Low	High	MFA available on admin accounts; magic-link login by default; session tokens HMAC-signed and short-lived

#	Risk	Likelihood	Impact	Treatment
2	Public results page exposes student first/last name + time	Medium	Low	Default display is “first name + surname-initial”; full surname is opt-in by school; per-carnival publication toggle; per-event noindex headers
3	Re-identification of students from public results across multiple carnivals	Low	Medium	Year level not published with results page; only race time + bib + display name; rate-limited public API
4	Sub-processor data breach (Cloudflare, Stripe, Resend)	Low	Medium	All sub-processors are SOC 2 Type II + ISO 27001 + GDPR-aligned; school is notified within 72h of confirmed breach
5	Data residency outside Australia	Low	Medium	All primary storage is in Cloudflare’s Sydney region; cross-border replication to AU regions only
6	School staff misuse of student data	Low	Medium	Audit log of all admin actions; school is data controller and is responsible for staff conduct under their existing privacy policy
7	Parent-view feature exposes one student’s data to wrong parent	Low	High	Parent-student linkage is created by school admin only; parents cannot self-link; quarterly link review reminder

#	Risk	Likelihood	Impact	Treatment
8	Vendor lock-in / data portability	Low	Medium	Full CSV export available on demand; schema published in product docs

4. Compliance alignment

Australian Privacy Principles (APP 1–13)

APP	Compliance
1 — Open and transparent management	Privacy policy published at /privacy on each product domain
2 — Anonymity and pseudonymity	Public results default to first-name + surname-initial
3 — Collection of solicited information	Only data necessary for sport administration is collected
4 — Unsolicited information	Excess information returned in CSV imports is auto-discarded
5 — Notification of collection	Parental consent template provided to schools (see PARENTAL_CONSENT.md)
6 — Use and disclosure	Data used only for stated purpose; no marketing use; no sale
7 — Direct marketing	No direct marketing to students or parents
8 — Cross-border disclosure	All primary processing in AU; sub-processors disclosed in § 6
9 — Government identifiers	None collected
10 — Quality	School admin can correct any record at any time
11 — Security	Encryption at rest + in transit; MFA available; 90-day log retention
12 — Access	School admin can view/export all records; parent access via school
13 — Correction	Self-serve correction by school admin; OAIC complaint pathway documented

Notifiable Data Breaches scheme

SSP supports the school in meeting NDB obligations. In the event of a breach involving school data, SSP will notify the school within 72 hours and provide forensic detail necessary for the school to assess “serious harm” and notify OAIC and affected individuals.

5. State-specific addenda

Victoria (DET, Catholic, independent)

- Aligned to **Privacy and Data Protection Act 2014 (Vic)** — Information Privacy Principles (IPPs).
- DET Schools Privacy Policy (2020) compatible — see “Acceptable use of third-party services” §6.4.
- Specific match to *Schedule 1 — Information Privacy Principles*: IPPs 4 (security), 9 (transborder data flows), and 11 (sensitive information — none collected).
- Data Sharing & Release Schedule (DSRS) — not triggered as no DET dataset is shared.

New South Wales (DoE, Catholic, independent)

- Aligned to **Privacy and Personal Information Protection Act 1998 (NSW)** — Information Protection Principles (IPPs).
- NSW DoE Privacy Code of Practice 2017 — Section 9 (third-party suppliers): SSP supplies a Data Processing Agreement to schools (see DATA_PROCESSING_AGREEMENT.md).
- DoE T4L compatibility statement available on request.

Queensland (DoE, Catholic, independent)

- Aligned to **Information Privacy Act 2009 (Qld)** — IPPs (for QLD government schools) and NPPs (for non-government).
- QLD DoE Procurement Standard — Information Security: SOC 2 Type II evidence available on request via Cloudflare.

Western Australia (DoE, Catholic, independent)

- WA does not have specific schools privacy legislation. Aligned to APPs and DoE WA Information Sharing Procedure.

South Australia, Tasmania, ACT, NT

- Aligned to APPs (federal) plus state public-sector privacy law where it applies to the school. SA Information Privacy Principles, ACT *Information Privacy Act 2014*, NT *Information Act 2002*.

Catholic and Independent schools (national)

- Schools governed by their diocesan/board privacy framework. SSP provides DPA + this PIA + parental consent templates as inputs to that framework.
- Catholic Education Melbourne, Sydney Catholic Schools, Brisbane Catholic Education — DPA template adapted for diocesan trustee structure available on request.

6. Sub-processors

Sub-processor	Service	Data residency	Compliance
Cloudflare Inc.	Hosting, D1, KV, R2	Sydney AU primary; AU-only replication	SOC 2 Type II, ISO 27001, GDPR DPA, FedRAMP

Sub-processor	Service	Data residency	Compliance
Stripe Inc.	Payments (schools only — no student data)	AU + US redundancy	PCI DSS Level 1, SOC 2 Type II
Resend Inc.	Transactional email	US (subject of next-version review)	SOC 2 Type II
GitHub Inc. (Microsoft)	Source code only — no customer data	US	SOC 2 Type II, ISO 27001

Sub-processors are added or changed only with 30 days’ notice to the school; opt-out termination right preserved in DPA.

7. Conclusion

The proposed use of School Sport Portal involves the processing of low-sensitivity personal information (name, year level, sport results) under a clear contractual framework with a vendor that meets Australian Privacy Principles, supports the school’s NDB obligations, and provides extensive controls including default name minimisation, opt-in publication, MFA, audit logging, and data export.

The residual privacy risk is **LOW** when: - The school applies its standard parental-consent process (template provided). - The school nominates a single privacy contact for SSP correspondence. - The school sets the public-results default to “first-name + surname-initial”.

8. Authorisation

Role	Name	Signature	Date
School Privacy Officer			
Business Manager			
Principal			
SSP — Patrick Gallivan, Director	Patrick Gallivan	<i>signed</i>	

Document version 1.0 — May 2026. Revisions tracked at https://github.com/LuckDragonAsgard/asgard-workers/blob/main/commercial/PRIVACY_IMPACT_ASSESSMENT.md